

TLP:CLEAR

INCIDENT REPORT

CraxsRAT Android RAT disguised as a "Safe Russia" app — spyware, SMS/OTP theft and full remote device control

Android RAT • CraxsRAT (MaaS) • Banker • Dropper • Accessibility Abuse

Parameter	Value
Report date	23 July 2026
Object	Safe_Russia.apk (two-stage dropper + CraxsRAT)
Classification	Android RAT / Spyware / Banker (multi-stage dropper)
Threat level	HIGH
Family / MaaS	CraxsRAT (Malware-as-a-Service; development attributed to actor EVLF)
Targeting	Russian-speaking users; delivery via hijacked Telegram accounts

1. Executive summary

We analysed the Android sample "Safe_Russia.apk", which masquerades as a security/VPN app called "Safe Russia". The file is malicious: a two-stage dropper delivering the commercial remote-access trojan (RAT) CraxsRAT. It is distributed via hijacked Telegram accounts and targets Russian-speaking users.

The outer app is a thin loader (it requests only the permission to install packages). Inside, a second APK is encrypted (XOR, key 0x5A) — CraxsRAT itself (package com.veloxapp.speedcore) — which the dropper convinces the user to install via the system installer. Once the Accessibility service is enabled, the malware gains near-total control of the device: keylogging and screen reading, interception of SMS and notifications (theft of one-time codes / OTP → banking fraud), overlay phishing, screen/microphone/camera recording, access to location, contacts and files, and self-protection against removal.

CraxsRAT is an off-the-shelf tool (Malware-as-a-Service), so attribution to a specific individual or group from the sample is not possible. The reasonable profile is a Russian-speaking, financially motivated operator leveraging a security/VPN theme and related social engineering around the MAX messenger and "voting" lures.

2. Object of analysis

Parameter	Value
File name	Safe_Russia.apk
Size	6,750,966 bytes (6.4 MB)
SHA-256 (stage 1, dropper)	5f94e59c132a7ed0e35b60146d973a728ab9f390c8291f9547cee26c56427738
SHA-256 (stage 2, CraxsRAT)	fc99609172910a8fad9522b374f8bae21e5805abdf052a49029edb53620a8e8c
Package (stage 1)	com.uisy.cache.installertest
Package (stage 2)	com.veloxapp.speedcore
Display name	Safe Russia (Cyrillic homoglyphs s, i)
Build date (stage 2)	versionCode 2026070301 (2026-07-03)

3. Kill chain

#	Stage	Description
1	Social engineering	Victims receive "Safe Russia.apk" via hijacked Telegram accounts, disguised as a security/VPN app.
2	Dropper install	The user installs the outer APK — a thin loader (only meaningful permission: REQUEST_INSTALL_PACKAGES). Poses as a VPN.
3	Payload unpack	The dropper decrypts the embedded APK via XOR (key 0x5A) → valid stage-2 APK.
4	Malware install	com.veloxapp.speedcore is installed via the PackageInstaller Session API

		(social-engineered "tap install").
5	Accessibility activation	The user is persuaded to enable Accessibility. The RAT then auto-grants permissions, reads the screen and emulates taps.
6	Persistence	Foreground services, boot autostart, battery-optimisation exemption, OEM autostart-manager evasion.
7	C2 communication	Persistent TCP socket to a C2 server on a non-standard port: screen/audio streaming, app-list exfiltration, command handling.
8	Theft & surveillance	SMS interception (priority 999) and notifications → OTP codes; overlay phishing; screen/mic/camera recording; location, contacts, files.

4. Technical analysis

4.1. Stage 1 — dropper (com.uisy.cache.installertest)

- The display name "Safe Russia" uses Cyrillic homoglyphs (s U+0455, i U+0456) — visually identical to "Safe Russia".
- Only meaningful permission: REQUEST_INSTALL_PACKAGES — a classic thin installer.
- Carries an encrypted payload (7.76 MB), XOR key 0x5A → stage-2 APK. Installs via PackageInstaller Session API.
- Disguised as a VPN ("Safe Russia = secure VPN" lure).
- Anti-analysis: the classes.dex ZIP entry has a zeroed CRC-32 (00000000) — unzip/apktool extract 0 bytes, whereas Android and androguard read the dex normally. A simple signature for detection.

4.2. Stage 2 — CraxsRAT (com.veloxapp.speedcore)

- Core: an AccessibilityService (label "Safe Russia", capabilities=169: read window content + gestures): keylogging, auto-grant, auto-click.
- NotificationListener "Notification Reader" — steals notification content (including OTP codes).
- SMS receiver with priority 999 + SEND/READ/RECEIVE_SMS — intercepts incoming SMS (bank codes), silent sending.
- Overlay phishing (SYSTEM_ALERT_WINDOW); hardcoded target — messenger.com.
- Surveillance: screen recording (MediaProjection), camera, microphone, location, contacts, storage access, calls, WRITE_SECURE_SETTINGS.
- Persistence: OEM boot receivers (Xiaomi/Huawei/Oppo/Vivo/Meizu/Smartisan); evasion via <queries> over vendor security/battery managers.
- Crypto: BouncyCastle (config/traffic obfuscation). C2 transport: raw TCP socket (optionally TLS), auto-reconnect, streaming.

5. Indicators of compromise (IOC)

Type	Value
SHA-256 (dropper)	5f94e59c132a7ed0e35b60146d973a728ab9f390c8291f9547cee26c56427738
SHA-256 (CraxsRAT)	fc99609172910a8fad9522b374f8bae21e5805abdf052a49029edb53620a8e8c
MD5 (dropper)	541e1d211a172b9353e347e292f34555
Package (stage 1)	com.uisy.cache.installertest

Package (stage 2)	com.veloxapp.speedcore
Domain (MAX phishing)	golosovanie-v-maxe[.]digital
Domain (MAX phishing)	maxnost-golos[.]lol
Domain (MAX phishing)	maxmab[.]lol

Note: some network indicators (the C2 server and related infrastructure) are withheld in this public version to avoid prematurely alerting the operator.

6. MITRE ATT&CK (Mobile)

Technique	ID
Masquerading / Deliver Malicious App	T1655 / T1660
Ingress Tool Transfer (two-stage dropper)	T1644
Obfuscated/Encrypted Payload (XOR, zeroed CRC)	T1406 / T1628
Abuse Accessibility Services	T1626 / T1517
Input Capture / Keylogging	T1417
SMS / OTP Interception	T1636.004 / T1582
Screen / Audio / Video Capture	T1513 / T1429 / T1512
Location Tracking / Contacts / Files	T1430 / T1636.003 / T1533
Boot Persistence	T1624.001
C2 over non-standard socket	T1571 / T1437

7. Recommendations

- Users: do not install "VPN/security" apps from Telegram links; a request to enable Accessibility for an unknown app is a red flag.
- MDM/detection: non-system packages with WRITE_SECURE_SETTINGS plus an enabled Accessibility service; off-store APKs; SMS receivers with priority 999.
- Detection rule: APK whose classes.dex entry has CRC-32 = 0, and/or an asset that XOR-0x5A decodes to a valid APK.
- Audit apps for Accessibility-service abuse and SMS/notification access.

TLP:CLEAR — This document may be distributed without restriction.